

**RISK ASSESSMENT REPORT (RAR)**  
**SAMP Walk-in clinic**  
**September 29, 2025**

| <b>Student Name</b> | <b>Role</b>                        |
|---------------------|------------------------------------|
| Parth Patel         | System Administrator               |
| Michael Tai         | Chief Information Security Officer |
| Augustine Ofosu     | Business Process Owner             |
| Samuel Nyarko       | IT manager                         |

## Table of Contents

|                                                                                                |    |
|------------------------------------------------------------------------------------------------|----|
| 1.0 Scenario & Organizational Context.....                                                     | 3  |
| 2.0 Implementation Group.....                                                                  | 3  |
| 3.0 Risk Management Tiers.....                                                                 | 4  |
| 4.0 Risk Assessment Approach.....                                                              | 5  |
| 4.1 Inventory of the Assets.....                                                               | 6  |
| 4.2 Threat Sources.....                                                                        | 8  |
| 4.3 Threat Events, Vulnerabilities & Predisposing Conditions, Severity &<br>Pervasiveness..... | 11 |
| 4.4 Threat Events, Likelihood, Impact & Risk Level.....                                        | 23 |
| 4.5 Risk Mitigation Controls.....                                                              | 39 |
| 5.0 Residual Risks (Sample).....                                                               | 69 |
| Works Cited.....                                                                               | 71 |

## **1.0 Scenario & Organizational Context:**

The SAMP walk-in clinic is a medium-sized community provider offering same-day medical services to a diverse community, assisting patients with minor illnesses or injuries.

The clinic strives to be a reliable and convenient source for same-day medical care, making it easy for people of all ages to receive appropriate care and evaluations. Services include family doctor visits and medical imaging, such as X-rays and MRI scans, both of which are managed by professional medical staff. The clinic sees approximately 150 patients weekly and has an estimated CAD \$3 million in government grants, insurance payments, and patient fees annually.

The organization employs approximately 30 people, including 8 physicians, 10 nurses, 2 receptionists, 5 administrative personnel, and 5 IT support members.

Moreover, the clinic has previously used paper-based health records, which have led to inefficient patient care, slow information sharing, and an increased risk of misplaced or incomplete documents. The IT consultant suggested that the clinic transition to a cloud-based system to manage their electronic health records and other information, as it would enable real-time access to records. As a result, the clinic will invest CAD \$750,000 in a digital transformation program to implement a cloud-based Electronic Health Record (EHR) and information management system. This will address these issues and enhance service performance.

The walk-in clinic also features a telemedicine platform, allowing physicians to connect with patients via video appointments for medical consultations.

Hence, technology plays a critical role in healthcare delivery and due to the sensitive nature of patient health information and other essential systems, it is essential to conduct a risk assessment to evaluate threats and vulnerabilities, determine the level of risk for each asset, and implement controls to mitigate these risks.

## **2.0 Implementation Group:**

### **IG2**

The SAMP walk-in clinic is classified as IG2 (Implementation Group 2) because it is considered a medium-sized organization and it has the IT and security personnel to help manage and protect the IT infrastructure within the clinic. The clinic must also comply with significant regulatory compliance obligations, which require the implementation of IG2 controls. For example, the clinic must comply with the Personal Health Information Protection Act (PHIPA) in Ontario. Since the clinic stores and processes confidential patient health information and records, it carries a high risk profile. A major concern is that any security breach resulting in compromised patient data could severely damage the clinic's trustworthiness and public confidence.

### **3.0 Risk Assessment Tiers**

Our risk assessment on the SAMP walk-in clinic covers all three tiers.

#### **Tier 1: Organizational**

There are a number of high-level risks related to the walk-in clinic that have an impact on the entire organization, which include reputational, legal, and operational risks.

First and foremost, patient privacy is our top priority. Additional risks include mishandling financial or insurance information, failing to secure sensitive data, and issues with third-party vendor services, all of which can result in legal and regulatory consequences.

The walk-in clinic is an organization with multiple stakeholders, including physicians, staff members, administrators, third-party vendors, IT and security personnel, and others. It operates through interconnected relationships among people, processes, and resources, all working together to provide quality healthcare. However, the organization also faces risks at the organizational level. These are types of risks that impact everyone and can undermine their credibility, trustworthiness, and reputation within the community.

#### **Tier 2: Mission**

The walk-in clinic also presents risks that could compromise critical business processes essential to the organization's mission, such as delivering patient care, scheduling appointments, processing medical billing, and providing medical imaging services.

Every process is important to the clinic's mission of providing timely and quality healthcare. The impact of the risks comes from the operational effectiveness of the clinic operations and processes.

#### **Tier 3: Technical**

The clinic uses multiple technologies and applications to store, process, and transmit confidential and sensitive patient health information to provide timely and quality healthcare to patients. For example, the clinic transitioned to a cloud-based system that helps to better manage electronic health records and information management systems to help with scheduling appointments, producing medical billing, and more. Any technical failure or security breach could violate patient privacy and disrupt normal clinic operations, leading to a catastrophic impact on the entire clinic.

## 4.0 Risk Assessment Approach

Assessment Approach: Qualitative

Likelihood Descriptive Labels: Low, Medium, High

Impact Descriptive Labels: Low, Medium, High, Catastrophic

### **Likelihood Scale:**

Low: Unlikely to occur (rare events, strong controls in place).

Moderate: Possible occurrence (occasional incidents or moderate vulnerabilities).

High: Likely occurrence (frequent incidents or easily exploitable vulnerabilities).

### **Impact Scale:**

Low: Minimal effect on operations or patient care; limited financial/reputation impact.

Moderate: Noticeable disruptions; potential harm to some patients or moderate financial impact.

High: Severe disruption to healthcare services, significant patient safety risk, or regulatory penalties.

Very High: Catastrophic effect on patient safety, major financial/reputation damage, or regulatory noncompliance.

We selected a qualitative approach for this risk assessment. Qualitative methods enabled us to assess the likelihood and impact of risks using descriptive labels such as “Low,” “Medium,” “High,” or “Catastrophic.” This approach can help leadership prioritize risks and ensure that safeguards and controls are allocated where they are needed most. Furthermore, since the clinic is required to comply with regulatory frameworks like PHIPA, organizations must identify risks to patient data, assess their impact and likelihood, and implement safeguards. A qualitative risk assessment is more practical in this context, as it aligns with regulatory expectations and produces results that clinic staff can easily understand while maintaining compliance with patient health information regulations. Hence, a qualitative approach to this risk assessment would be the convenient approach to use to conduct a risk assessment about this medium-sized clinic, while also producing actionable insights to help carry out the appropriate actions to mitigate the risks.

## 4.1 Inventory of the Assets

### 1. Devices:

| Enterprise Assets                                                                                                                                            | End-user Devices                                                                                   | IoT Devices            | Network Devices                                                                                             |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|------------------------|-------------------------------------------------------------------------------------------------------------|
| X-ray imaging machine<br>Printer/Scanner<br>MRI imaging machine<br>Operational Technology Devices (Lighting)<br>Operational Technology Devices (HVAC system) | Receptionist Desktop/Workstation<br><br>Laptops<br><br>Tablets<br><br>Smartphones<br><br>Wearables | IoT-enabled thermostat | Wireless Router<br><br>Wireless Access Points<br><br>Network Firewall<br><br>Network Attached Storage (NAS) |

### 2. Software

| Applications                                                                                                                                                                                                                                                             | Operating Systems |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|
| Cloud-based Electronic Health Record Management Software<br><br>Cloud-based Patient Scheduling System<br><br>Patient Portal Application<br><br>Staff Portal Application<br><br>Cloud-based Medical Billing Software<br><br>Telemedicine Platform<br><br>Active Directory | Windows OS        |

|                                                                                                                                                                                                       |  |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|
| <p>Cloud Storage Account</p> <p>Clinical Decision Support System</p> <p>Radiology Information System</p> <p>Email System</p> <p>Prescription Management System</p> <p>Data Loss Prevention System</p> |  |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|

### 3. Data

| Sensitive Data                                                                                                                                                                                                                                                                                                                                        | Log Data                                                                                                  |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|
| <p>Patient Personally Identifiable Information (PII)</p> <p>Electronic Protected Health Information (demographics, medical histories, test results)</p> <p>Imaging data from radiology information systems</p> <p>Financial Information (Insurance, Credit Card Information)</p> <p>Employee Information/Records (PII, Payroll information, etc.)</p> | <p>Electronic Health Record Database</p> <p>Audit and System Activity Logs</p> <p>Access Control Logs</p> |

### 4. Users

| <b>Workforce</b>                                                                               | <b>Service Providers</b>                                                             |
|------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Clinic Staff (Physicians, Nurses, Receptionists, Administrative Personnel, IT Support Members) | IT and Security Personnel<br>Cloud Provider<br>Third Party Service Providers/Vendors |

## 5. Network

| <b>Network Infrastructure</b>                                                 | <b>Network Architecture</b>                                                                  |
|-------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| Wired Connection (Ethernet)<br>Server Infrastructure for hosting applications | Routing Systems<br>Local Area Network Connection (LAN)<br>Wide Area Network Connection (WAN) |

## 6. Documentation

| <b>Plan</b>                                                              | <b>Policy</b>                                                    | <b>Procedure</b>                      | <b>Process</b>                                                |
|--------------------------------------------------------------------------|------------------------------------------------------------------|---------------------------------------|---------------------------------------------------------------|
| Business Continuity and Disaster Recovery Plan<br>Incident Response Plan | Business Associate Agreement<br>Security Policies and Procedures | Security Awareness Training Materials | Domain names<br>SSL Certificates<br>License Keys for Software |

## 4.2 Threat Sources

| <b>Threat Sources</b> | <b>Threat source Characteristics (Capability)</b> | <b>Threat source Characteristics (Intent)</b> | <b>Threat source Characteristics (Targeting)</b> | <b>Threat Events</b> |
|-----------------------|---------------------------------------------------|-----------------------------------------------|--------------------------------------------------|----------------------|
|                       |                                                   |                                               |                                                  |                      |



|                                                                                                                                     |           |           |           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------------------------------------------------------------------------------------------------------------------------------|-----------|-----------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Malicious Insiders<br>(Employees, contractors, or third-party vendors with authorized access who misuse their access intentionally) | High      | Moderate  | High      | Employees modify or misuse critical data, or external contractors and third-party vendors steal critical data for financial gain, espionage, revenge, or coercion                                                                                                                                                                                                                                                                                                                       |
| Negligent or Untrained Insiders<br>Staff members who unintentionally expose data due to lack of cybersecurity training.             | Low       | Very low  | Very low  | <p>Medical staff members unknowingly click on phishing links that would lead to credentials theft, thus access to confidential health data.</p> <p>Negligent security officer misconfiguring access controls to confidential data, thus leading to unauthorized access to critical data by unprivileged staff.</p> <p>Medical employees recklessly misplace devices with access to confidential data, leading to compromise of the device/data should it fall into malicious hands.</p> |
| Politically sponsored hackers                                                                                                       | High      | High      | High      | <p>Successful hack attempts by hackers leading to data leaks of clients' confidential health data can damage the reputation of SAMP clinic and its clients.</p> <p>DDOS attacks on critical health data systems by hackers attempting to brute force the system or disable its primary functions.</p>                                                                                                                                                                                   |
| Cybercriminals                                                                                                                      | Very high | Very high | Very high | Cybercriminals successfully gaining                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

|                                                                                    |          |          |          |                                                                                                                                                                                                                                                                                                        |
|------------------------------------------------------------------------------------|----------|----------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                    |          |          |          | access to the data system via malware would plant ransomware, or perform data theft for sale (PHI fetches a high price on dark web), or use the stolen data for insurance fraud schemes                                                                                                                |
| Third Party Service Providers                                                      | Low      | Very Low | Very Low | Cloudy's Cloud service experiences an unplanned system downtime, leading to unintended service outage of access to critical health data, thus halting or reducing the efficiency of the clinic's response to patient health issues.                                                                    |
| Natural Disasters (Worn-out facilities leading to damage to organizational assets) | Very low | Very low | Very low | Damaged or worn-out internal water facilities or power surges cause damage to data processing and/or storage devices, leading to halts or reducing the efficiency of the clinic's response to patient health issues.                                                                                   |
| Unnatural Disasters (Sabotage or destruction by human means)                       | Low      | Low      | Moderate | Riot, as a result of public discontent with governmental views or revenge against the clinic or its executive staff for past grievances, leads to intentional damage to data processing or storage devices, thus halting or reducing the efficiency of the clinic's response to patient health issues. |

### 4.3 Threat Events, Vulnerabilities & Predisposing Conditions, Severity & Pervasiveness

**Qualitative Scale:**

**Severity:** Low, Moderate, High, Very High

**Pervasiveness:** Low, Moderate, High, Very High

| Threat Events                                                                                                                                                                                                                                                                                                                   | Vulnerabilities & Predisposing Conditions                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Severity & Pervasiveness                                 |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|
| <p>Assets: Personally Identifiable Information, Personal Health Information, Electronic Health Records, Financial Information</p> <p>Staff clinic employees modify or misuse critical patient data, or external contractors and third-party vendors steal critical data for financial gain, espionage, revenge, or coercion</p> | <ul style="list-style-type: none"> <li>- Insider threats - medical staff members, external contractors, or third-party vendors with authorized access to the clinic's critical facilities have malicious intentions against the clinic, another medical worker or a certain patient.</li> <li>- Weak access control - access to critical health facilities or data storage devices are not managed properly, thus accessible to unprivileged individuals</li> <li>- Lack of strong monitoring and auditing of who tends to access electronic health records and other critical data</li> </ul> | <p>Severity - moderate<br/>Pervasiveness - very high</p> |
| <p>Assets: Tablets, PII, PHI, Financial Information, Electronic Health Record</p>                                                                                                                                                                                                                                               | <p>Negligent or untrained medical staff recklessly expose the clinic's</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | <p>Severity - moderate<br/>Pervasiveness - moderate</p>  |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |                                                           |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------|
| <p>Database</p> <p>Medical staff members unknowingly click on phishing links that would lead to credentials theft, thus access to confidential health data in the patient portal.</p> <p>Negligent security officer misconfiguring access controls to confidential data, thus leading to unauthorized access to critical data by unprivileged staff.</p> <p>Medical employees recklessly misplace devices (tablets, etc.) with access to confidential data, leading to compromise of the device/data should it fall into malicious hands.</p>      | <p>confidential data or access to such data</p>                                                                                                                                                                                                                                                                                                                                                                                                                          |                                                           |
| <p>Assets: Cloud-based Electronic Health Record Management Software, Cloud-based Patient Scheduling System, Patient Portal Application, Staff Portal Application, Cloud-based Medical Billing Software, Clinical Decision Support System</p> <p>Successful hack attempts by hackers leading to data leaks of clients' confidential health data can damage the reputation of SAMP clinic and its clients.</p> <p>DDOS attacks on critical health data systems by hackers attempting to brute force the system or disable its primary functions.</p> | <ul style="list-style-type: none"> <li>- Poorly configured health systems and databases</li> <li>- Unpatched medical software applications</li> <li>- Weak or reused employee user passwords</li> <li>- Successful phishing attacks on medical staff</li> <li>- Logging of sensitive patient data</li> <li>- Unrestricted access to the clinic's internal network,</li> <li>- Lack of network traffic throttling,</li> <li>- Insecure IoMT devices leading to</li> </ul> | <p>Severity - very high<br/>Pervasiveness - very high</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |                                                      |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                                                          | botnet attacks on critical medical assets                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                                                      |
| <p>Assets: Personally Identifiable Information, Personal Health Information, Electronic Health Records, Financial Information</p> <p>Cybercriminals successfully gaining access to the data system via malware would plant ransomware, or perform data theft for sale (PHI and PII fetches a high price on the dark web), or use the stolen data (financial information) for insurance fraud schemes</p> | <ul style="list-style-type: none"> <li>- Unpatched medical software applications,</li> <li>- Weak or reused employee user passwords,</li> <li>- Successful phishing attacks on medical staff,</li> <li>- Logging of sensitive patient data</li> <li>- Unrestricted access to the clinic's internal network</li> </ul>                                                                                                                                                                                                                           | <p>Severity - high<br/>Pervasiveness - very high</p> |
| <p>Asset: Cloud Server Infrastructure</p> <p>Cloudy's Cloud service experiences an unplanned system downtime, leading to unintended service outage of access to critical health data thus halting or reducing the efficiency of the clinic's response to patient health issues.</p>                                                                                                                      | <ul style="list-style-type: none"> <li>- The clinic lacks a secondary cloud service provider, which creates a problem in case the primary provider fails to supply their service.</li> <li>- Outdated or damaged cloud service hardware leads to malfunctions.</li> <li>- Cloud service software misconfigurations can lead to the inaccessibility of critical medical data in the cloud.</li> <li>- DDOS attacks by hackers can lead to exhaustion of network resources, thus, resources would be unavailable for genuine access to</li> </ul> | <p>Severity - high<br/>Pervasiveness - very high</p> |

|                                                                                                                                                                                                                                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                      |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
|                                                                                                                                                                                                                                       | <p>medical data.</p> <ul style="list-style-type: none"> <li>- Ransomware or malware in the system prevents medical staff from accessing the necessary medical data for resolving a patient's medical case.</li> </ul>                                                                                                                                                                                                                                                                                                            |                                                      |
| <p>Damaged or worn-out internal water facilities or power surges cause damage to data processing and/or storage devices, leading to halts or reducing the efficiency of the clinic's response to patient health issues.</p>           | <ul style="list-style-type: none"> <li>- Poor physical hardware design or quality of the medical data storage devices</li> <li>- Faulty UPS</li> <li>- Lack of environmental controls for protecting the data storage devices</li> <li>- Poor building infrastructure or design of the room that protects the data storage devices</li> <li>- Poor system and room temperature monitoring systems</li> <li>- Accidents caused by human errors that lead to exposure or direct damage of medical data storage devices.</li> </ul> | <p>Severity - high<br/>Pervasiveness - very high</p> |
| <p>Asset: Data processing and storage devices</p> <p>Riot, as a result of public discontent with governmental views or revenge against the clinic or its executive staff for past grievances, leads to intentional damage of data</p> | <ul style="list-style-type: none"> <li>- Unsecured server rooms due to a lack of locks and access keys</li> <li>- Lack of surveillance or access logs to monitor entry into the server room</li> </ul>                                                                                                                                                                                                                                                                                                                           | <p>Severity - moderate<br/>Pervasiveness - high</p>  |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |                                                                                                                                                                                                                         |                                                         |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| processing or storage devices, thus halting or reducing the efficiency of the clinic's response to patient health issues.                                                                                                                                                                                                                                                                                                                                                                                                                                                | - Inadequate lock systems or a lack of perimeter security personnel                                                                                                                                                     |                                                         |
| <p>Asset: X-ray imaging machine, MRI imaging machine</p> <p>A cybercriminal can manipulate the X-ray and MRI machine's operational settings (exposure levels, protocols, commands), which can result in incorrect images and treatment plans that can endanger patients (Nguyen et al., 2025) (Open MedScience Imaging Health, 2024)</p> <ul style="list-style-type: none"> <li>- Involves unauthorized modification, which adversely impacts organizational assets (X-ray imaging machine) and individuals (patients) (Open MedScience Imaging Health, 2024)</li> </ul> | Insecure protocols in the radiology information system, which could lead to unauthorized modification of the imaging device via a man-in-the-middle attack (Nguyen et al., 2025) (Open MedScience Imaging Health, 2024) | <p>Severity - high</p> <p>Pervasiveness - high</p>      |
| <p>Asset: Printer/Scanner</p> <p>The possibility of unpatched printer firmware exploitation to gain access to the printer to make further lateral movement to other parts of the clinic network (Novatech, 2025)</p>                                                                                                                                                                                                                                                                                                                                                     | Unpatched firmware (Novatech, 2025)                                                                                                                                                                                     | <p>Severity - high</p> <p>Pervasiveness - moderate</p>  |
| <p>Asset: Lighting</p> <p>If there is a fire or flood and the lights go out during an evacuation, it can pose a danger to staff and patients</p> <p>OR</p> <p>If there is heavy rainfall, it can</p>                                                                                                                                                                                                                                                                                                                                                                     | Lighting operates on the same electrical circuit as the IT equipment and medical machines, resulting in an outage across all critical systems                                                                           | <p>Severity - high</p> <p>Pervasiveness - very high</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                            |                                                                                                                                                                 |                                                         |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| lead to a power outage, which can cause the clinic to go dark and disrupt patient care operations                                                                                                                                                                                                                                                                                                                                                          |                                                                                                                                                                 |                                                         |
| <p>Asset: HVAC</p> <p>Equipment such as imaging devices and other IT equipment that rely on stable cooling may overheat due to neglected maintenance work on HVAC</p>                                                                                                                                                                                                                                                                                      | Maintenance work may not be done well, as there could be dirty filters, worn parts or infrequent inspections that could lead to uncomfortable room temperatures | <p>Severity - high</p> <p>Pervasiveness - moderate</p>  |
| <p>Assets: Receptionist Desktop/Workstation, Receptionist</p> <p>A receptionist could walk away from their desktop, and a patient could view all the private health information of another patient, especially if there is no automatic lock policy on the desktop that locks the workstation after inactivity (Miller, 2025).</p> <p>This can result in a violation of privacy regulations (PHIPA) and can lead to reputational damage to the clinic.</p> | Lack of lock protection after system inactivity on the receptionist workstation/desktop (Miller, 2025)                                                          | <p>Severity - very high</p> <p>Pervasiveness - high</p> |
| <p>Asset: Laptop</p> <p>Chance of malware infection via USB drive, which can cause any adversary to steal and copy patient data (Alder, 2019)</p>                                                                                                                                                                                                                                                                                                          | External ports are left open, which could allow any malicious adversary to copy data or inject malware (Alder, 2019)                                            | <p>Severity - high</p> <p>Pervasiveness - high</p>      |
| <p>Asset: IoT-based thermostat</p> <p>Attackers can exploit the IoT thermostat through the outdated software and change the temperature dramatically, and use it as a pivot point (backdoor to the network) to laterally move to desktops,</p>                                                                                                                                                                                                             | No encryption, or the software might be outdated (Tran, 2025)                                                                                                   | <p>Severity - high</p> <p>Pervasiveness - high</p>      |



|                                                                                                                                                                                                                                                                                                                                  |                                                                                                            |                                                         |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| cloud accounts, EHR systems, etc (Tran, 2025).                                                                                                                                                                                                                                                                                   |                                                                                                            |                                                         |
| <p>Asset: Wireless Router</p> <p>An attacker could compromise the router by installing malicious code, which could turn the router into a botnet that is then controlled remotely by the attacker to inject malware into other connected devices, such as IoT thermostats, tablets and other devices connected to the Wi-Fi.</p> | Weak admin credentials                                                                                     | <p>Severity - high</p> <p>Pervasiveness - high</p>      |
| <p>Asset: Wireless Access Points</p> <p>A remote attacker can perform a man-in-the-middle attack on wireless traffic, stealing credentials and sensitive information.</p>                                                                                                                                                        | Misconfiguration on the wireless access point                                                              | <p>Severity - high</p> <p>Pervasiveness - high</p>      |
| <p>Asset: Local Area Network Connection (LAN)</p> <p>Attackers could flood the LAN, causing congestion and disrupting clinic services (SOPHOS, n.d)</p>                                                                                                                                                                          | Lack of strong network security protocols to prevent traffic floods                                        | <p>Severity - high</p> <p>Pervasiveness - high</p>      |
| <p>Asset: Wide Area Network Connection (WAN)</p> <p>Once past the firewall of the network, the attacker could impose a ransomware attack that could encrypt the patient files and other information</p>                                                                                                                          | Insecure protocols and a lack of protection can allow the attacker to get past the firewall                | <p>Severity - very high</p> <p>Pervasiveness - high</p> |
| <p>Asset: Routing System</p> <p>Attackers could send malicious packets into the routing system, which can disrupt routing, cause confusion for routers and create congestion, leading to a DoS attack (Intelligent CIO Europe, n.d)</p>                                                                                          | Routing system might have an insufficient input validation system on packets (Intelligent CIO Europe, n.d) | <p>Severity - high</p> <p>Pervasiveness - high</p>      |

|                                                                                                                                                                                                                                                                                       |                                                                                                                                                                         |                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------|
| <p>Asset: Patient Scheduling System</p> <p>The attacker could send a phishing email to a staff member, and if they are successful, they could use the patient scheduling system as a stepping stone to access other critical systems (Sandoval, 2025)</p>                             | <p>Lack of security awareness can cause clinic staff to respond to phishing emails</p>                                                                                  | <p>Severity - very high<br/>Pervasiveness - very high</p> |
| <p>Asset: Medical Billing Software</p> <p>Data exfiltration attack on PHI and financial information (supply chain attack) as medical billing depend on third-party vendors</p>                                                                                                        | <p>API vulnerability as the API connecting the billing software to the EHR could be poorly secured, resulting in potential attackers to intercept data (Zmed, 2025)</p> | <p>Severity - very high<br/>Pervasiveness - very high</p> |
| <p>Asset: Telemedicine Platform</p> <p>If the communication channel between the physician and the patient does not have end-to-end encryption, attackers could listen and steal confidential information, thus violating patient and physician privacy (Eagle Telemedicine, 2024)</p> | <p>Unsecure communication channel due to lack of strong encryption over the end-to-end connection</p>                                                                   | <p>Severity - high<br/>Pervasiveness - high</p>           |
| <p>Asset: Medical Prescription System</p> <p>An attacker could be tampering with online patient prescription information, such as dosage, drug type, which can cause harm to patients if they are given the wrong information</p>                                                     | <p>Weak authentication controls</p>                                                                                                                                     | <p>Severity - very high<br/>Pervasiveness - high</p>      |
| <p>Asset: Picture Archiving and Communication System for Radiology Information Systems</p> <p>An Attacker could infiltrate the PACS through an infected device via phishing attack or</p>                                                                                             | <p>Lack of endpoint protection on devices that may be connected to the same network as the PACS</p>                                                                     | <p>Severity - high<br/>Pervasiveness - high</p>           |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                                               |                                                              |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------|
| malware and once they get inside the system, they could alter diagnostic images, which can result in incorrect treatment plans and endanger patient safety (RadSource, 2024)                                                                                                                                                                                                                                                                                                                                      |                                                                                                                                                               |                                                              |
| <p>Asset: Email System</p> <p>An attacker could use spyware to get unauthorized access to confidential emails</p>                                                                                                                                                                                                                                                                                                                                                                                                 | <p>Lack of authentication measures in the email system can increase the risk of unauthorized access to confidential emails and exposure to electronic PHI</p> | <p>Severity - high</p> <p>Pervasiveness - high</p>           |
| <p>Asset: Clinical Decision Support System</p> <p>A malicious adversary could manipulate the algorithms and decisions that are provided by the clinical decision support system (leading to incorrect clinical recommendations)</p>                                                                                                                                                                                                                                                                               | <p>Insecure API that allow attackers to modify system logic</p>                                                                                               | <p>Severity - very high</p> <p>Pervasiveness - high</p>      |
| <p>Asset: Cloud Storage Account</p> <p>An attacker might disable storage account audit logs to prevent tracking and avoid detection.</p> <p>They might even disable cloud workload protection which usually provides security alerts for any unusual or malicious activities in cloud services.</p> <p>This allows them to place a backdoor in which they have remote control and they can get unauthorized access to the cloud system containing critical information. (Microsoft Threat Intelligence, 2023)</p> | <p>Insufficient monitoring of the status of security services</p>                                                                                             | <p>Severity - very high</p> <p>Pervasiveness - very high</p> |
| <p>Asset: Employee Information</p> <p>An attacker might use a remote</p>                                                                                                                                                                                                                                                                                                                                                                                                                                          | <p>Outdated endpoint protection</p>                                                                                                                           | <p>Severity - high</p> <p>Pervasiveness - moderate</p>       |

|                                                                                                                                                                                                                                                                  |                                                                                                                                                                                                                                              |                                                            |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| access trojan to exfiltrate HR and employee data, leading to unauthorized access to confidential employee information                                                                                                                                            |                                                                                                                                                                                                                                              |                                                            |
| <p>Asset: Access Control Lists</p> <p>The attacker might conduct an SQL injection into the database to cause privilege escalation</p>                                                                                                                            | There might be a lack of tampering prevention controls for the database                                                                                                                                                                      | <p>Severity - high</p> <p>Pervasiveness - high</p>         |
| <p>Asset: Firewall</p> <p>An attacker could conduct a denial of service attack that would flood the firewall with excessive traffic, which could result in legitimate service downtime and patients may not get the medical care they need on time if needed</p> | Firewall could have a lack of throughput as hardware may not be able to handle too much traffic                                                                                                                                              | <p>Severity - high</p> <p>Pervasiveness - high</p>         |
| <p>Asset: System Activity Logging System</p> <p>The attacker is tampering with the log data to hide their presence in the system activity logging, which means they could be adding malicious code to create a backdoor without anyone noticing</p>              | Log data might not be properly encoded on the logging or monitoring system, leaving it vulnerable for attackers to inject fake entries to hide their activity and to make others think that something else happened (OWASP Top 10:2021, n.d) | <p>Severity - high</p> <p>Pervasiveness - high</p>         |
| <p>Asset: Physical Alarm System</p> <p>With a faulty alarm system, any thief can come into the clinic and steal equipment</p>                                                                                                                                    | Lack of maintenance or faulty sensors that are not discovered until a break-in occurs                                                                                                                                                        | <p>Severity - moderate</p> <p>Pervasiveness - moderate</p> |
| <p>Asset: Physician</p> <p>An attacker might use a social engineering attack to conduct a whaling attack towards a physician by sending them a fake email pretending to be a patient or IT support.</p>                                                          | Lack of security awareness training as a physician may not be able to recognize a phishing attack                                                                                                                                            | <p>Severity - high</p> <p>Pervasiveness - high</p>         |

|                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                  |                                                            |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| The physician might get deceived into revealing login credentials, which the attacker can use to steal confidential information                                                                                                                                                                                                                                    |                                                                                                                                                  |                                                            |
| <p>Asset: Domain names</p> <p>The attacker could exploit the domain of the patient portal or other critical systems if the domain is not renewed on time (canspace, 2023).</p> <p>They could be using the expired domain to conduct phishing attacks to trick patients and staff into downloading malware or providing sensitive information (canspace, 2023).</p> | <p>Not renewing the domain can lead to the domain being unprotected</p> <p>Staff not being trained well enough to detect a phishing campaign</p> | <p>Severity - high</p> <p>Pervasiveness - high</p>         |
| <p>Asset: License Keys for the Software</p> <p>The attacker could steal the license keys for piracy and to sell patient information that may be on the software</p>                                                                                                                                                                                                | Lack of key management can leave the license keys vulnerable to attackers who may use them for illegal use                                       | <p>Severity - moderate</p> <p>Pervasiveness - moderate</p> |
| <p>Asset: SSL certificate</p> <p>The attacker could use the expired SSL certificate and conduct a man-in-the-middle attack to intercept patient health information during a telemedicine video call between a physician and patient</p>                                                                                                                            | Not renewing the SSL certificates can leave the website connections insecure                                                                     | <p>Severity - high</p> <p>Pervasiveness - high</p>         |
| <p>Assets: Incident Response Plan, Business Continuity Plan Documentation</p> <p>An attacker could tamper with the details of the incident</p>                                                                                                                                                                                                                     | Not having a backup hard copy of the incident response and business continuity plans leads to a single point of failure (weak backup practices)  | <p>Severity - high</p> <p>Pervasiveness - high</p>         |

|                                                                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                       |                                                            |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| response plan and business continuity plan, or they might even delete it, which makes things worse when there is no backup copy available                                                                                                                                                                                                                                                                          |                                                                                                       |                                                            |
| <p>Asset: Digital copy of the Business Associate Agreement between clinic and third party vendors</p> <p>With an online copy of the business associate agreement between the clinic and the third party vendor, attackers could tamper with the details of the agreement and it can't be proven otherwise that it wasn't modified with the absence of digital signature</p>                                        | There might not be a digital signature to prove integrity and accountability                          | <p>Severity - moderate</p> <p>Pervasiveness - moderate</p> |
| <p>Asset: Third Party Provider (Cloud Provider, etc.)</p> <p>The outsourced data center belonging to the third party vendor, responsible for many of the clinic's services, may be vulnerable to natural disasters such as wildfires</p> <p>This can lead to business continuity risk, especially if the plan has not been tested for such circumstances or if there is no backup plan</p> <p>(Jewhurst, 2024)</p> | Lack of business continuity plan testing                                                              | <p>Severity - moderate</p> <p>Pervasiveness - moderate</p> |
| <p>Asset: Active Directory</p> <p>An attacker might attempt to extract credentials from a highly privileged account during sessions of accounts that are currently signed in (highly likely for accounts with elevated privileges), and then mimic the actions of the identity</p>                                                                                                                                 | Having privileged accounts with the same credentials across multiple systems (Microsoft Ignite, 2025) | <p>Severity - very high</p> <p>Pervasiveness - high</p>    |

|                                                                                                                                                                                                                                 |                                                                                                                                                                                             |                                         |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------|
| to gain access to other systems (Microsoft Ignite, 2025).                                                                                                                                                                       |                                                                                                                                                                                             |                                         |
| <b>Asset: Ethernet</b><br><br>Attacker might be able to eavesdrop on the network traffic and gain access to sensitive information, such as patient information and other confidential records (Electronic Office Systems, 2023) | Lack of security measures such as strong encryption across an Ethernet connection, can leave networks vulnerable to attackers, allowing them to see what is going on in the network traffic | Severity - high<br>Pervasiveness - high |
| <b>Asset: Windows OS</b><br><br>An attacker may inject malicious data as part of a command to trick the system into tampering with the patient/clinic systems (Granot, 2024)                                                    | Lack of input validation                                                                                                                                                                    | Severity - high<br>Pervasiveness - high |

## 4.4 Threat Events, Likelihood, Impact & Risk Level

Qualitative Scale:

**Relevance of threat event:** Anticipated, Possible, Expected, N/A

**Likelihood of Attack Initiation:** Low, Moderate, High, Very High

**Likelihood Initiated Attack Succeeds:** Low, Moderate, High, Very High

**Overall Likelihood:** Low, Moderate, High, Very High

**Level of Impact:** Low, Moderate, High, Very High

**Risk:** Low, Moderate, High, Very High

| Threat Events                                                                    | Relevance of threat event | Likelihood of attack initiation | Likelihood Initiated Attack Succeeds | Overall likelihood | Level of Impact | Risk |
|----------------------------------------------------------------------------------|---------------------------|---------------------------------|--------------------------------------|--------------------|-----------------|------|
| <b>Assets:</b> Personally Identifiable Information, Personal Health Information, | Possible                  | Moderate                        | Very High                            | High               | High            | High |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |          |      |           |           |          |          |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|------|-----------|-----------|----------|----------|
| <p>Electronic Health Records, Financial Information</p> <p>Clinic staff employees could modify or misuse critical data, or external contractors and third-party vendors could steal critical data for financial gain, espionage, revenge, or coercion</p>                                                                                                                                                                                                                                                                                                            |          |      |           |           |          |          |
| <p><b>Assets:</b> Tablets, PII, PHI, Financial Information, Electronic Health Record Database</p> <p>Medical staff members unknowingly click on phishing links that would lead to credentials theft, thus gaining access to confidential health data in the patient portal.</p> <p>Negligent security officer misconfiguring access controls to confidential data, thus leading to unauthorized access to critical data by unprivileged staff.</p> <p>Medical employees recklessly misplace devices (tablets, etc.) with access to confidential data, leading to</p> | Expected | High | Very High | Very High | Moderate | Moderate |



|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |             |      |           |           |           |           |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|------|-----------|-----------|-----------|-----------|
| compromise of the device/data should it fall into malicious hands.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |             |      |           |           |           |           |
| <b>Assets:</b><br>Cloud-based Electronic Health Record Management Software, Cloud-based Patient Scheduling System, Patient Portal Application, Staff Portal Application, Cloud-based Medical Billing Software, Clinical Decision Support System<br><br>Successful hack attempts by hackers leading to data leaks of clients' confidential health data can damage the reputation of SAMP clinic and its clients.<br><br>DDOS attacks on critical health data systems by hackers attempting to brute force the system or disable its primary functions. | Anticipated | High | High      | High      | Moderate  | Moderate  |
| <b>Assets:</b> PII, PHI, Financial Information, Electronic Health Record Database                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Expected    | High | Very High | Very High | Very High | Very High |

|                                                                                                                                                                                                                                                                                            |          |          |           |          |      |          |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|----------|-----------|----------|------|----------|
| <p>Cybercriminals successfully gaining access to the data system via malware would plant ransomware, or perform data theft for sale (PHI and PII fetches a high price on the dark web), or use the stolen data (financial information) for insurance fraud schemes</p>                     |          |          |           |          |      |          |
| <p><b>Asset:</b> Cloud server infrastructure</p> <p>Cloudy's Cloud service experiences an unplanned system downtime, leading to unintended service outage of access to critical health data thus halting or reducing the efficiency of the clinic's response to patient health issues.</p> | Possible | Moderate | Very High | High     | High | High     |
| <p><b>Asset:</b> Data processing and storage devices</p> <p>Damaged or worn-out internal water facilities or power surges cause damage to data processing and/or storage devices, leading to halts or reducing the</p>                                                                     | Possible | Low      | High      | Moderate | High | Moderate |

|                                                                                                                                                                                                                                                                                                                                                                                                                                          |             |          |      |      |           |           |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|------|------|-----------|-----------|
| efficiency of the clinic's response to patient health issues.                                                                                                                                                                                                                                                                                                                                                                            |             |          |      |      |           |           |
| Riot, as a result of public discontent with governmental views or revenge against the clinic or its executive staff for past grievances, leads to intentional damage of data processing or storage devices, thus halting or reducing the efficiency of the clinic's response to patient health issues.                                                                                                                                   | N/A         | Very Low | High | Low  | High      | Low       |
| <p>Asset: X-ray imaging machine, MRI imaging machine</p> <p>A cybercriminal can manipulate the X-ray and MRI machine's operational settings (exposure levels, protocols, commands), which can result in incorrect images and treatment plans that can endanger patients (Nguyen et al., 2025) (Open MedScience Imaging Health, 2024)</p> <p>Involves unauthorized modification, which adversely impacts organizational assets (X-ray</p> | Anticipated | Moderate | High | High | Very High | Very High |

|                                                                                                                                                                                                                                                                                                        |             |          |           |          |      |      |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|-----------|----------|------|------|
| imaging machine) and individuals (patients) (Open MedScience Imaging Health, 2024)                                                                                                                                                                                                                     |             |          |           |          |      |      |
| <p>Asset: Printer/Scanner</p> <p>The possibility of unpatched printer firmware exploitation to gain access to the printer to make further lateral movement to other parts of the clinic network (Novatech, 2025)</p>                                                                                   | Anticipated | Moderate | High      | High     | High | High |
| <p>Asset: Lighting</p> <p>If there is a fire or flood and the lights go out during an evacuation, it can pose a danger to staff and patients</p> <p>OR</p> <p>If there is heavy rainfall, it can lead to a power outage, which can cause the clinic to go dark and disrupt patient care operations</p> | Expected    | Low      | Very High | Moderate | High | High |
| <p>Asset: HVAC</p> <p>Equipment such as imaging devices and other IT equipment that rely on stable cooling may overheat due to neglected</p>                                                                                                                                                           | Expected    | Low      | High      | Moderate | High | High |

|                                                                                                                                                                                                                                                                                                                                     |             |          |      |           |           |           |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|------|-----------|-----------|-----------|
| maintenance work on HVAC                                                                                                                                                                                                                                                                                                            |             |          |      |           |           |           |
| <p>Assets: Receptionist Desktop/Workstation , Receptionist</p> <p>A receptionist could walk away from their desktop, and a patient could view all the private health information of another patient, especially if there is no automatic lock policy on the desktop that locks the workstation after inactivity (Miller, 2025).</p> | Expected    | Moderate | High | High      | Moderate  | High      |
| <p>Asset: Laptop</p> <p>Chance of malware infection via USB drive, which can cause any adversary to steal and copy patient data (Alder, 2019)</p>                                                                                                                                                                                   | Anticipated | Moderate | High | High      | High      | High      |
| <p>Asset: IoT-based thermostat</p> <p>Attackers can exploit the IoT thermostat through the outdated software and change the temperature dramatically, and use it as a pivot point (backdoor to the network) to laterally move to desktops, cloud accounts, EHR</p>                                                                  | Anticipated | High     | High | Very High | Very High | Very High |

|                                                                                                                                                                                                                                                                                                                                  |             |          |           |           |           |           |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|-----------|-----------|-----------|-----------|
| systems, etc (Tran, 2025).                                                                                                                                                                                                                                                                                                       |             |          |           |           |           |           |
| <p>Asset: Wireless Router</p> <p>An attacker could compromise the router by installing malicious code, which could turn the router into a botnet that is then controlled remotely by the attacker to inject malware into other connected devices, such as IoT thermostats, tablets and other devices connected to the Wi-Fi.</p> | Anticipated | High     | High      | High      | Very High | Very High |
| <p>Asset: Wireless Access Points</p> <p>A remote attacker can perform a man-in-the-middle attack on wireless traffic, stealing credentials and sensitive information.</p>                                                                                                                                                        | Expected    | High     | Very High | Very High | High      | Very High |
| <p>Asset: Local Area Network Connection (LAN)</p> <p>Attackers could flood the LAN, causing congestion and disrupting clinic services (SOPHOS, n.d)</p>                                                                                                                                                                          | Possible    | Moderate | High      | High      | High      | High      |
| Asset: Wide Area Network Connection (WAN)                                                                                                                                                                                                                                                                                        | Anticipated | High     | Very High | Very High | Very High | Very High |

|                                                                                                                                                                                                                                                           |             |          |           |           |           |           |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|-----------|-----------|-----------|-----------|
| Once past the firewall of the network, the attacker could impose a ransomware attack that could encrypt the patient files and other information                                                                                                           |             |          |           |           |           |           |
| <p>Asset: Routing System</p> <p>Attackers could send malicious packets into the routing system, which can disrupt routing, cause confusion for routers and create congestion, leading to a DoS attack (Intelligent CIO Europe, n.d)</p>                   | Expected    | Moderate | High      | High      | High      | High      |
| <p>Asset: Patient Scheduling System</p> <p>The attacker could send a phishing email to a staff member, and if they are successful, they could use the patient scheduling system as a stepping stone to access other critical systems (Sandoval, 2025)</p> | Expected    | High     | High      | High      | High      | High      |
| <p>Asset: Medical Billing Software</p> <p>Data exfiltration attack on PHI and financial information (supply chain attack) as medical billing depend on</p>                                                                                                | Anticipated | High     | Very High | Very High | Very High | Very High |

|                                                                                                                                                                                                                                                                                       |          |      |           |           |           |           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|------|-----------|-----------|-----------|-----------|
| third-party vendors                                                                                                                                                                                                                                                                   |          |      |           |           |           |           |
| <p>Asset: Telemedicine Platform</p> <p>If the communication channel between the physician and the patient does not have end-to-end encryption, attackers could listen and steal confidential information, thus violating patient and physician privacy (Eagle Telemedicine, 2024)</p> | Expected | High | High      | High      | Very High | Very High |
| <p>Asset: Medical Prescription System</p> <p>An attacker could be tampering with online patient prescription information, such as dosage, drug type, which can cause harm to patients if they are given the wrong information</p>                                                     | Expected | High | High      | High      | Very High | Very High |
| <p>Asset: Picture Archiving and Communication System for Radiology Information Systems</p> <p>An Attacker could infiltrate the PACS through an infected device via phishing attack or malware and once they get inside the system, they could alter diagnostic images,</p>            | Expected | High | Very High | Very High | Very High | Very High |



|                                                                                                                                                                                                                                                                                                     |             |          |           |           |           |           |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|-----------|-----------|-----------|-----------|
| which can result in incorrect treatment plans and endanger patient safety (RadSource, 2024)                                                                                                                                                                                                         |             |          |           |           |           |           |
| <p>Asset: Email System</p> <p>An attacker could use spyware to get unauthorized access to confidential emails</p>                                                                                                                                                                                   | Anticipated | High     | High      | High      | High      | High      |
| <p>Asset: Clinical Decision Support System</p> <p>A malicious adversary could manipulate the algorithms and decisions that are provided by the clinical decision support system (leading to incorrect clinical recommendations)</p>                                                                 | Anticipated | Moderate | High      | High      | Very High | Very High |
| <p>Asset: Cloud Storage Account</p> <p>An attacker might disable storage account audit logs to prevent tracking and avoid detection.</p> <p>They might even disable cloud workload protection which usually provides security alerts for any unusual or malicious activities in cloud services.</p> | Anticipated | High     | Very High | Very High | Very High | Very High |

|                                                                                                                                                                                                                                                                  |             |          |      |      |      |      |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|------|------|------|------|
| <p>This allows them to place a backdoor in which they have remote control and they can get unauthorized access to the cloud system containing critical information.<br/>(Microsoft Threat Intelligence, 2023)</p>                                                |             |          |      |      |      |      |
| <p>Asset: Employee Information</p> <p>An attacker might use a remote access trojan to exfiltrate HR and employee data, leading to unauthorized access to confidential employee information</p>                                                                   | Expected    | Moderate | High | High | High | High |
| <p>Asset: Access Control Lists</p> <p>The attacker might conduct an SQL injection into the database to cause privilege escalation</p>                                                                                                                            | Anticipated | High     | High | High | High | High |
| <p>Asset: Firewall</p> <p>An attacker could conduct a denial of service attack that would flood the firewall with excessive traffic, which could result in legitimate service downtime and patients may not get the medical care they need on time if needed</p> | Expected    | Moderate | High | High | High | High |

|                                                                                                                                                                                                                                                                                                                                                |             |          |           |           |           |           |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|-----------|-----------|-----------|-----------|
| <p>Asset: System Activity Logging System</p> <p>The attacker is tampering with the log data to hide their presence in the system activity logging, which means they could be adding malicious code to create a backdoor without anyone noticing</p>                                                                                            | Anticipated | High     | Very High | Very High | Very High | Very High |
| <p>Asset: Physical Alarm System</p> <p>With a faulty alarm system, any thief can come into the clinic and steal equipment</p>                                                                                                                                                                                                                  | Possible    | Low      | Moderate  | Low       | High      | Moderate  |
| <p>Asset: Physician</p> <p>An attacker might use a social engineering attack to conduct a whaling attack towards a physician by sending them a fake email pretending to be a patient or IT support.</p> <p>The physician might get deceived into revealing login credentials, which the attacker can use to steal confidential information</p> | Expected    | High     | High      | High      | High      | High      |
| <p>Asset: Domain names</p> <p>The attacker could</p>                                                                                                                                                                                                                                                                                           | Anticipated | Moderate | High      | High      | High      | High      |

|                                                                                                                                                                                                                                                                                                                      |             |          |          |      |           |           |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|----------|------|-----------|-----------|
| <p>exploit the domain of the patient portal or other critical systems if the domain is not renewed on time (canspace, 2023).</p> <p>They could be using the expired domain to conduct phishing attacks to trick patients and staff into downloading malware or providing sensitive information (canspace, 2023).</p> |             |          |          |      |           |           |
| <p>Asset: License Keys for the Software</p> <p>The attacker could steal the license keys for piracy and to sell patient information that may be on the software</p>                                                                                                                                                  | Possible    | Low      | Moderate | Low  | Moderate  | Moderate  |
| <p>Asset: SSL certificate</p> <p>The attacker could use the expired SSL certificate and conduct a man-in-the-middle attack to intercept patient health information during a telemedicine video call between a physician and patient</p>                                                                              | Anticipated | Moderate | High     | High | Very High | Very High |
| <p>Assets: Incident Response Plan, Business Continuity Plan Documentation</p>                                                                                                                                                                                                                                        | Anticipated | Moderate | High     | High | High      | High      |

|                                                                                                                                                                                                                                                                                                                                                                             |             |     |          |          |           |          |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|-----|----------|----------|-----------|----------|
| <p>An attacker could tamper with the details of the incident response plan and business continuity plan, or they might even delete it, which makes things worse when there is no backup copy available</p>                                                                                                                                                                  |             |     |          |          |           |          |
| <p>Asset: Digital copy of the Business Associate Agreement between clinic and third party vendors</p> <p>With an online copy of the business associate agreement between the clinic and the third party vendor, attackers could tamper with the details of the agreement and it can't be proven otherwise that it wasn't modified with the absence of digital signature</p> | Possible    | Low | Moderate | Low      | High      | Moderate |
| <p>Asset: Third Party Provider (Cloud Provider, etc.)</p> <p>The outsourced data center belonging to the third party vendor, responsible for many of the clinic's services, may be vulnerable to natural disasters such as wildfires</p>                                                                                                                                    | Anticipated | Low | High     | Moderate | Very High | High     |

|                                                                                                                                                                                                                                                                                                                                              |             |          |           |           |           |           |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------|-----------|-----------|-----------|-----------|
| <p>This can lead to business continuity risk, especially if the plan has not been tested for such circumstances or if there is no backup plan</p> <p>(Jewhurst, 2024)</p>                                                                                                                                                                    |             |          |           |           |           |           |
| <p>Asset: Active Directory</p> <p>An attacker might attempt to extract credentials from a highly privileged account during sessions of accounts that are currently signed in (highly likely for accounts with elevated privileges), and then mimic the actions of the identity to gain access to other systems (Microsoft Ignite, 2025).</p> | Expected    | High     | Very High | Very High | Very High | Very High |
| <p>Asset: Ethernet</p> <p>Attacker might be able to eavesdrop on the network traffic and gain access to sensitive information, such as patient information and other confidential records (Electronic Office Systems, 2023)</p>                                                                                                              | Anticipated | Moderate | High      | High      | High      | High      |
| <p>Asset: Windows OS</p> <p>An attacker may</p>                                                                                                                                                                                                                                                                                              | Expected    | High     | High      | High      | High      | High      |

|                                                                                                                              |  |  |  |  |  |  |
|------------------------------------------------------------------------------------------------------------------------------|--|--|--|--|--|--|
| inject malicious data as part of a command to trick the system into tampering with the patient/clinic systems (Granot, 2024) |  |  |  |  |  |  |
|------------------------------------------------------------------------------------------------------------------------------|--|--|--|--|--|--|

### 4.5 Mitigation Controls:

**Framework:** CIS Critical Security Controls Version 8.1

We implemented controls for all risks, including high priority risks.

| Threat Events                                                                                                                                                                                                                                                                                                                   | Controls to mitigate identified risks                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Assets: Personally Identifiable Information, Personal Health Information, Electronic Health Records, Financial Information</p> <p>Staff clinic employees modify or misuse critical patient data, or external contractors and third-party vendors steal critical data for financial gain, espionage, revenge, or coercion</p> | <ul style="list-style-type: none"> <li>- Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</li> <li>- Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</li> <li>- Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</li> <li>- Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</li> <li>- Segregation of duty (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</li> <li>- Perform background checks and periodic employee evaluations (CIS control 18 - Safeguard 18.5: Perform Periodic Internal Penetration Tests)</li> <li>- Implement alerts to the supervisor for critical data changes (CIS control 8 - Safeguard 8.11: Conduct Audit Log Reviews)</li> </ul> |
| <p><b>Assets:</b> Tablets, PII, PHI, Financial Information, Electronic Health Record Database</p>                                                                                                                                                                                                                               | <ul style="list-style-type: none"> <li>- Enable employee training on cybersecurity techniques (CIS control 14 - Safeguard 14.2: Train</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Medical staff members unknowingly click on phishing links that would lead to credentials theft, thus gaining access to confidential health data in the patient portal.</p> <p>Negligent security officer misconfiguring access controls to confidential data, thus leading to unauthorized access to critical data by unprivileged staff.</p> <p>Medical employees recklessly misplace devices (tablets, etc.) with access to confidential data, leading to compromise of the device/data should it fall into malicious hands.</p> | <p>Workforce Members to Recognize Social Engineering Attacks)</p> <ul style="list-style-type: none"> <li>- Perform periodic phishing drills (CIS control 14 - Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks)</li> <li>- Email Filtering &amp; Anti-Phishing Tools (CIS control 9 - Safeguard 9.6: Block Unnecessary File Types)</li> <li>- Block access to known malicious sites (CIS control 9 - Safeguard 9.3: Maintain and Enforce Network-Based URL Filters)</li> <li>- Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</li> <li>- Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</li> <li>- Implement logging for access controls (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</li> <li>- Implement device data encryption (CIS control 3 - Safeguard 3.6: Encrypt Data on End-User Devices)</li> <li>- Implement remote device management capability (CIS control 4 - Safeguard 4.11: Enforce Remote Wipe Capability on Portable End-User Devices)</li> <li>- Reinforce strong password requirement on devices (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</li> <li>- Implement asset inventory &amp; tracking (CIS control 1 - Safeguard 1.1: Establish and Maintain Detailed Enterprise Asset Inventory)</li> <li>- Implement device timeout settings (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</li> </ul> |
| <p><b>Assets:</b> Cloud-based Electronic Health Record Management Software, Cloud-based Patient Scheduling System, Patient Portal Application, Staff Portal Application,</p>                                                                                                                                                                                                                                                                                                                                                          | <ul style="list-style-type: none"> <li>- Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</li> <li>- Implement timeout sessions (CIS control 4 -</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |



|                                                                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Cloud-based Medical Billing Software, Clinical Decision Support System</p> <p>Successful hack attempts by hackers leading to data leaks of clients' confidential health data can damage the reputation of SAMP clinic and its clients.</p> <p>DDOS attacks on critical health data systems by hackers attempting to brute force the system or disable its primary functions.</p> | <p>Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <ul style="list-style-type: none"> <li>- Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</li> <li>- Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</li> <li>- Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</li> <li>- Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</li> <li>- Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</li> <li>- Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</li> <li>- Implement network traffic throttling (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</li> <li>- Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</li> <li>- Implement auto-scaling of network resources during peak season (CIS control 12 - Safeguard 12.8: Establish and Maintain Dedicated Computing Resources for All Administrative Work)</li> <li>- Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</li> </ul> |
| <p><b>Assets:</b> PII, PHI, Financial Information, Electronic Health Record Database</p> <p>Cybercriminals successfully gaining access to the data system via malware would plant ransomware, or perform</p>                                                                                                                                                                        | <ul style="list-style-type: none"> <li>- Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</li> <li>- Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |

|                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>data theft for sale (PHI and PII fetches a high price on the dark web), or use the stolen data (financial information) for insurance fraud schemes</p>                                                                                                                          | <p>on Enterprise Assets)</p> <ul style="list-style-type: none"> <li>- Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</li> <li>- Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</li> <li>- Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</li> <li>- Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</li> <li>- Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</li> <li>- Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</li> <li>- Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</li> <li>- Setup honeypots (CIS control 10 - Safeguard 10.5: Enable Anti-Exploitation Features)</li> <li>- Reinforce strong password policy (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</li> <li>- Restrict portable storage device usage privilege (CIS control 10 - Safeguard 10.3: Disable Autorun and Autoplay for Removable Media)</li> </ul> |
| <p>Asset: Cloud Server Infrastructure</p> <p>Cloudy's Cloud service experiences an unplanned system downtime leading to unintended service outage of access to critical health data thus halting or reducing the efficiency of the clinic's response to patient health issues.</p> | <ul style="list-style-type: none"> <li>- Deploy to multiple data centers (CIS control 11 - Safeguard 11.3: Protect Recovery Data)</li> <li>- Implement automated regular data backups (CIS control 11 - Safeguard 11.2: Perform Automated Backups)</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

|                                                                                                                                                                                                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                       | <ul style="list-style-type: none"> <li>- Implement disaster prevention and recovery planning policy (CIS control 11 - Safeguard 11.1: Establish and Maintain a Data Recovery Process)</li> <li>- Use multiple service providers (CIS control 15 - Safeguard 15.1: Establish and Maintain an Inventory of Service Providers)</li> <li>- Perform regular system configuration evaluations (CIS control 4 - Safeguard 4.2: Establish and Maintain a Secure Configuration Process for Network Infrastructure)</li> <li>- Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</li> <li>- Implement network traffic throttling (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</li> <li>- Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</li> <li>- Implement auto-scaling of network resources during peak season (CIS control 12 - Safeguard 12.8: Establish and Maintain Dedicated Computing Resources for All Administrative Work)</li> <li>- Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</li> <li>- Setup honeypots (CIS control 10 - Safeguard 10.5: Enable Anti-Exploitation Features)</li> <li>- Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</li> <li>- Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</li> </ul> |
| Damaged or worn-out internal water facilities or power surges cause damage to data processing and/or storage devices, leading to halts or reducing the efficiency of the clinic's response to patient | <ul style="list-style-type: none"> <li>- Restrict physical access to data centers via locks, access cards, access privileges (CIS control 6 - Safeguard 6.1: Establish an Access Granting Process)</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |

|                                                                                                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>health issues.</p>                                                                                                                                                                                                                                                                                           | <ul style="list-style-type: none"> <li>- Implement disaster prevention environmental systems (fire suppression systems, smoke detectors, HVAC systems) (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</li> <li>- Proper Cabling and Power Management (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</li> <li>- Regular data backups (CIS control 11 - Safeguard 11.2: Perform Automated Backups)</li> <li>- Deploy to multiple data centers (CIS control 11 - Safeguard 11.3: Protect Recovery Data)</li> <li>- Implement disaster prevention and recovery planning policy (CIS control 11 - Safeguard 11.1: Establish and Maintain a Data Recovery Process)</li> <li>- Provide employee training on accident prevention (CIS control 14 - Safeguard 14.6: Train Workforce Members on Recognizing and Reporting Security Incidents)</li> <li>- Proactively identify and mitigate potential risks (CIS control 7 - Safeguard 7.7: Remediate Detected Vulnerabilities)</li> </ul> |
| <p>Riot, resulting from public discontent with governmental views or revenge against the clinic or its executive staff for past grievances, leads to the intentional damage of data processing or storage devices, thus halting or reducing the clinic's efficiency in responding to patient health issues.</p> | <ul style="list-style-type: none"> <li>- Restrict physical access to data centers via locks, access cards, access privileges, reinforce barriers (CIS control 6 - Safeguard 6.1: Establish an Access Granting Process)</li> <li>- Implement disaster prevention environmental systems (fire suppression systems, smoke detectors, HVAC systems) (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</li> <li>- Regular data backups (CIS control 11 - Safeguard 11.2: Perform Automated Backups)</li> <li>- Provide security personnel and surveillance (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</li> <li>- Setup offsite data centers or deploy to multiple data centers (CIS control 11 - Safeguard 11.3: Protect Recovery Data)</li> </ul>                                                                                                                                                                                                                                     |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | <ul style="list-style-type: none"> <li>- Implement disaster prevention and recovery planning policy (CIS control 11 - Safeguard 11.1: Establish and Maintain a Data Recovery Process)</li> <li>- Monitor public state to detect emerging threats (CIS control 7 - Safeguard 7.7: Remediate Detected Vulnerabilities)</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <p>Asset: X-ray imaging machine, MRI imaging machine</p> <p>A cybercriminal can manipulate the X-ray and MRI machine's operational settings (exposure levels, protocols, commands), which can result in incorrect images and treatment plans that can endanger patients (Nguyen et al., 2025) (Open MedScience Imaging Health, 2024)</p> <p>Involves unauthorized modification, which adversely impacts organizational assets (X-ray imaging machine) and individuals (patients) (Open MedScience Imaging Health, 2024)</p> | <p>Reinforce strong password policy (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> |
| <p>Asset: Printer/Scanner</p> <p>The possibility of unpatched printer firmware exploitation to gain access to the printer to make further lateral movement to other parts of the clinic network (Novatech, 2025)</p>                                                                                                                                                                                                                                                                                                        | <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <p>Asset: Lighting</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | <p>Implement disaster prevention environmental systems (fire suppression systems, smoke detectors,</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

|                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>If there is a fire or flood and the lights go out during an evacuation, it can pose a danger to staff and patients.</p> <p>OR</p> <p>If there is heavy rainfall, it can lead to a power outage, which can cause the clinic to go dark and disrupt patient care operations.</p>                                                  | <p>HVAC systems) (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Proper Cabling and Power Management (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Regular data backups (CIS control 11 - Safeguard 11.2: Perform Automated Backups)</p>                                                                                                                                                                                                                                                                                                                                                  |
| <p>Asset: HVAC</p> <p>Equipment such as imaging devices and other IT equipment that rely on stable cooling may overheat due to neglected maintenance work on the HVAC</p>                                                                                                                                                          | <p>Implement disaster prevention environmental systems (fire suppression systems, smoke detectors, HVAC systems) (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <p>Assets: Receptionist Desktop/Workstation, Receptionist</p> <p>A receptionist could walk away from their desktop, and a patient could view all the private health information of another patient, especially if there is no automatic lock policy on the desktop that locks the workstation after inactivity (Miller, 2025).</p> | <p>Enable employee training on cybersecurity techniques (CIS control 14 - Safeguard 14.5: Train Workforce Members on Causes of Unintentional Data Exposure)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Reinforce strong password requirement on devices (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> <p>Implement device timeout settings (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> |
| <p>Asset: Laptop</p> <p>Chance of malware infection via USB drive, which can cause any adversary to steal and copy patient data (Alder, 2019)</p>                                                                                                                                                                                  | <p>Restrict portable storage device usage privilege (CIS control 10 - Safeguard 10.3: Disable Autorun and Autoplay for Removable Media)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management,</p>                                                                                                                                                                                                                                                                                                                                                             |

|                                                                                                                                                                                                                                                                                                                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                  | <p>Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| <p>Asset: IoT-based thermostat</p> <p>Attackers can exploit the IoT thermostat through the outdated software and change the temperature dramatically, and use it as a pivot point (backdoor to the network) to laterally move to desktops, cloud accounts, EHR systems, etc (Tran, 2025).</p>                                    | <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p>                                                                                                                                                                                                                                                                                                                                                            |
| <p>Asset: Wireless Router</p> <p>An attacker could compromise the router by installing malicious code, which could turn the router into a botnet that is then controlled remotely by the attacker to inject malware into other connected devices, such as IoT thermostats, tablets and other devices connected to the Wi-Fi.</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform</p> |

|                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                           | <p>Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Setup honeypots (CIS control 10 - Safeguard 10.5: Enable Anti-Exploitation Features)</p> <p>Reinforce strong password policy (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p>           |
| <p>Asset: Wireless Access Points</p> <p>A remote attacker can perform a man-in-the-middle attack on wireless traffic, stealing credentials and sensitive information.</p> | <p>Implement secure Wi-Fi protocols (CIS control 12 - Safeguard 12.6: Use of Secure Network Management and Communication Protocols)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> |



|                                                                                                                                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                         | <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <p>Asset: Local Area Network Connection (LAN)</p> <p>Attackers could flood the LAN, causing congestion and disrupting clinic services (SOPHOS, n.d)</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems</p> |

|                                                                                                                                                                                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                         | <p>(CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement network traffic throttling (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement auto-scaling of network resources during peak season (CIS control 12 - Safeguard 12.8: Establish and Maintain Dedicated Computing Resources for All Administrative Work)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> |
| <p>Asset: Wide Area Network Connection (WAN)</p> <p>Once past the firewall of the network, the attacker could impose a ransomware attack that could encrypt the patient files and other information</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p>                                                             |

|                                                                                                                                                                                                                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                         | <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Setup honeypots (CIS control 10 - Safeguard 10.5: Enable Anti-Exploitation Features)</p> <p>Reinforce strong password policy (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> |
| <p>Asset: Routing System</p> <p>Attackers could send malicious packets into the routing system, which can disrupt routing, cause confusion for routers and create congestion, leading to a DoS attack (Intelligent CIO Europe, n.d)</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p>                                                                                                                                                                                                                                                                                                                                    |

|                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                  | <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement network traffic throttling (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement auto-scaling of network resources during peak season (CIS control 12 - Safeguard 12.8: Establish and Maintain Dedicated Computing Resources for All Administrative Work)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> |
| Asset: Patient Scheduling System | Implement role-based access control (CIS control 6 -                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

|                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>The attacker could send a phishing email to a staff member, and if they are successful, they could use the patient scheduling system as a stepping stone to access other critical systems (Sandoval, 2025)</p> | <p>Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</p> <p>Segregation of duty (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Perform background checks and periodic employee evaluations (CIS control 18 - Safeguard 18.5: Perform Periodic Internal Penetration Tests)</p> <p>Implement alerts to supervisor for critical data changes (CIS control 8 - Safeguard 8.11: Conduct Audit Log Reviews)</p> |
| <p>Asset: Medical Billing Software</p> <p>Data exfiltration attack on PHI and financial information (supply chain attack) as medical billing depend on third-party vendors</p>                                    | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p>                                                                                                                                                                                                                                                                                                                                                                             |

|                                                                                                                                                                                                                                                                                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                       | <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)<br/>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> |
| <p>Asset: Telemedicine Platform</p> <p>If the communication channel between the physician and the patient does not have end-to-end encryption, attackers could listen and steal confidential information, thus violating patient and physician privacy (Eagle Telemedicine, 2024)</p> | <p>Implement secure protocols for communication lines (CIS control 3 - Safeguard 3.10: Encrypt Sensitive Data in Transit)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention</p>                                                                                                                                                             |

|                                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                   | <p>Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)<br/>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p>                                          |
| <p>Asset: Medical Prescription System</p> <p>An attacker could be tampering with online patient prescription information, such as dosage, drug type, which can cause harm to patients if they are given the wrong information</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability</p> |

|                                                                                                                                                                                                                                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                        | <p>Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Implement alerts to supervisor for critical data changes (CIS control 8 - Safeguard 8.11: Conduct Audit Log Reviews)</p> |
| <p>Asset: Picture Archiving and Communication System for Radiology Information Systems</p> <p>An Attacker could infiltrate the PACS through an infected device via phishing attack or malware and once they get inside the system, they could alter diagnostic images, which can result in incorrect treatment plans and endanger patient safety (RadSource, 2024)</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform</p>                                                                                             |



|                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|---------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                           | <p>Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)<br/>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Implement alerts to supervisor for critical data changes (CIS control 8 - Safeguard 8.11: Conduct Audit Log Reviews)</p> |
| <p>Asset: Email System</p> <p>An attacker could use spyware to get unauthorized viewing access to confidential emails</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p>                                                                                  |

|                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                     | <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <p>Asset: Clinical Decision Support System</p> <p>A malicious adversary could manipulate the algorithms and decisions that are provided by the clinical decision support system (leading to incorrect clinical recommendations)</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4:</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | <p>Perform Traffic Filtering Between Network Segments)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Implement alerts to supervisor for critical data changes (CIS control 8 - Safeguard 8.11: Conduct Audit Log Reviews)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <p>Asset: Cloud Storage Account</p> <p>An attacker might disable storage account audit logs to prevent tracking and avoid detection.</p> <p>They might even disable cloud workload protection which usually provides security alerts for any unusual or malicious activities in cloud services.</p> <p>This allows them to place a backdoor in which they have remote control and they can get unauthorized access to the cloud system containing critical information.<br/>(Microsoft Threat Intelligence, 2023)</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)<br/>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> |

|                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                | <p>implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Implement alerts to supervisor for critical data changes (CIS control 8 - Safeguard 8.11: Conduct Audit Log Reviews)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <p>Asset: Employee Information</p> <p>An attacker might use a remote access trojan to exfiltrate HR and employee data, leading to unauthorized access to confidential employee information</p> | <p>Require MFA for Administrative Access)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement logging for access controls (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement device data encryption (CIS control 3 - Safeguard 3.6: Encrypt Data on End-User Devices)</p> <p>Reinforce strong password requirement on devices (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> |

|                                                                                                                                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|---------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                       | <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <p>Asset: Access Control Lists</p> <p>The attacker might conduct an SQL injection into the database to cause privilege escalation</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement logging for access controls (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement device data encryption (CIS control 3 - Safeguard 3.6: Encrypt Data on End-User Devices)</p> <p>Reinforce strong password requirement on devices (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> <p>Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> |

|                                                                                                                                                                                                                                                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                  | Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <p>Asset: Firewall</p> <p>An attacker could conduct a denial of service attack that would flood the firewall with excessive traffic, which could result in legitimate service downtime and patients may not get the medical care they need on time if needed</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement network traffic throttling (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> |

|                                                                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                | <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Implement auto-scaling of network resources during peak season (CIS control 12 - Safeguard 12.8: Establish and Maintain Dedicated Computing Resources for All Administrative Work)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> |
| <p>Asset: System Activity Logging System</p> <p>The attacker is tampering with the log data to hide their presence in the system activity logging, which means they could be adding malicious code to create a backdoor without anyone noticing</p>                                                                                            | <p>Implement logging for access controls (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p>                                                                                                                                                                                                                                                                                                                                                                        |
| <p>Asset: Physical Alarm System</p> <p>With a faulty alarm system, any thief can come into the clinic and steal equipment</p>                                                                                                                                                                                                                  | <p>Restrict physical access to data centers via locks, access cards, access privileges, reinforce barriers (CIS control 6 - Safeguard 6.1: Establish an Access Granting Process)</p> <p>Provide security personnel and surveillance (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> <p>Implement disaster prevention and recovery planning policy (CIS control 11 - Safeguard 11.1: Establish and Maintain a Data Recovery Process)</p>       |
| <p>Asset: Physician</p> <p>An attacker might use a social engineering attack to conduct a whaling attack towards a physician by sending them a fake email pretending to be a patient or IT support.</p> <p>The physician might get deceived into revealing login credentials, which the attacker can use to steal confidential information</p> | <p>Enable employee training on cybersecurity techniques (CIS control 14 - Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks)</p> <p>Perform periodic phishing drills (CIS control 14 - Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks)</p> <p>Email Filtering &amp; Anti-Phishing Tools (CIS control 9 -</p>                                                                                             |

|                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                    | <p>Safeguard 9.6: Block Unnecessary File Types)</p> <p>Block access to known malicious sites (CIS control 9 - Safeguard 9.3: Maintain and Enforce Network-Based URL Filters)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement logging for access controls (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Reinforce strong password requirement on devices (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> |
| <p>Asset: Domain names</p> <p>The attacker could exploit the domain of the patient portal or other critical systems if the domain is not renewed on time (canspace, 2023).</p> <p>They could be using the expired domain to conduct phishing attacks to trick patients and staff into downloading malware or providing sensitive information (canspace, 2023).</p> | <p>Enable employee training on cybersecurity techniques (CIS control 14 - Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks)</p> <p>- Perform periodic phishing drills (CIS control 14 - Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks)</p> <p>- Block access to known malicious sites (CIS control 9 - Safeguard 9.3: Maintain and Enforce Network-Based URL Filters)</p>                                                                                                                                                                                                 |
| <p>Asset: License Keys for the Software</p> <p>The attacker could steal the license keys for piracy and to sell patient information that may be on the software</p>                                                                                                                                                                                                | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <p>Asset: SSL certificate</p>                                                                                                                                                                                                                                                                                                                                      | <p>Implement secure protocols for communication lines</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |



|                                                                                                                                                                                                                                                                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>The attacker could use the expired SSL certificate and conduct a man-in-the-middle attack to intercept patient health information during a telemedicine video call between a physician and patient</p>                                                                                | <p>(CIS control 3 - Safeguard 3.10: Encrypt Sensitive Data in Transit)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> |
| <p>Assets: Incident Response Plan, Business Continuity Plan Documentation</p> <p>An attacker could tamper with the details of the incident response plan and business continuity plan, or they might even delete it, which makes things worse when there is no backup copy available</p> | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p>                                                                        |

|                                                                                                                                                                                                                                                                                                                                                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                             | <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Setup honeypots (CIS control 10 - Safeguard 10.5: Enable Anti-Exploitation Features)</p> <p>Reinforce strong password policy (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> |
| <p>Asset: Digital copy of the Business Associate Agreement between clinic and third party vendors</p> <p>With an online copy of the business associate agreement between the clinic and the third party vendor, attackers could tamper with the details of the agreement and it can't be proven otherwise that it wasn't modified with the absence of digital signature</p> | <p>Implement digital signatures on confidential documents (CIS control 2 - Safeguard 2.7: Allowlist Authorized Scripts)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p>                                                                                                                                                                                                                                                                                                                                                                                                                            |

|                                                                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                                                                    | Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| <p>Asset: Third Party Provider (Cloud Provider, etc.)</p> <p>The outsourced data center belonging to the third party vendor, responsible for many of the clinic's services, may be vulnerable to natural disasters such as wildfires</p> <p>This can lead to business continuity risk, especially if the plan has not been tested for such circumstances or if there is no backup plan</p> <p>(Jewhurst, 2024)</p> | <p>Implement disaster prevention environmental systems (fire suppression systems, smoke detectors, HVAC systems) (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Proper Cabling and Power Management (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Regular data backups (CIS control 11 - Safeguard 11.2: Perform Automated Backups)</p> <p>Deploy to multiple data centers (CIS control 11 - Safeguard 11.3: Protect Recovery Data)</p> <p>Implement disaster prevention and recovery planning policy (CIS control 11 - Safeguard 11.1: Establish and Maintain a Data Recovery Process)</p> |
| <p>Asset: Active Directory</p> <p>An attacker might attempt to extract credentials from a highly privileged account during sessions of accounts that are currently signed in (highly likely for accounts with elevated privileges), and then mimic the actions of the identity to gain access to other systems (Microsoft Ignite, 2025).</p>                                                                       | <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data changes by user (CIS control 8 - Safeguard 8.5: Collect Detailed Audit Logs)</p> <p>Implement alerts to supervisor for critical data changes (CIS control 8 - Safeguard 8.11: Conduct Audit Log Reviews)</p>                                                  |

|                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                                                 | Train account users to be more responsible of the account they have been assigned (CIS control 14 - Safeguard 14.5: Train Workforce Members on Causes of Unintentional Data Exposure)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <p>Asset: Ethernet</p> <p>Attacker might be able to eavesdrop on the network traffic and gain access to sensitive information, such as patient information and other confidential records (Electronic Office Systems, 2023)</p> | <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement Geo-blocking / IP Blacklisting of known attack sources (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments)</p> <p>Setup honeypots (CIS control 10 - Safeguard 10.5: Enable Anti-Exploitation Features)</p> <p>Reinforce strong password policy (CIS control 5 - Safeguard 5.2: Use Unique Passwords)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> |
| Asset: Windows OS                                                                                                                                                                                                               | Implement data or command input validation policies (CIS control 16 - Safeguard 16.10: Apply Secure                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

|                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>An attacker may inject malicious data as part of a command to trick the system into tampering with the patient/clinic systems (Granot, 2024)</p> | <p>Design Principles in Application Architectures)</p> <p>Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)</p> <p>Implement timeout sessions (CIS control 4 - Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets)</p> <p>Enable Multi-factor authentication (CIS control 6 - Safeguard 6.5: Require MFA for Administrative Access)</p> <p>Enable logging of data transfers (CIS control 8 - Safeguard 8.2: Collect Audit Logs)</p> <p>Implement data encryption (CIS control 3 - Safeguard 3.11: Encrypt Sensitive Data at Rest)</p> <p>Implement data loss prevention policies (CIS control 3 - Safeguard 3.13: Deploy a Data Loss Prevention Solution)</p> <p>Perform periodic software updates and vulnerability scanning (CIS control 7 - Safeguard 7.4: Perform Automated Application Patch Management, Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets)</p> <p>Implement Firewalls &amp; Intrusion Prevention Systems (CIS control 13 - Safeguard 13.10: Perform Application Layer Filtering, Safeguard 13.8: Deploy a Network Intrusion Prevention Solution)</p> <p>Implement network monitoring tools (CIS control 13 - Safeguard 13.1: Centralize Security Event Alerting)</p> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## 5.0 Residual Risk (Sample)

The residual risk was determined for four of the threat events in which the inherent risk was moderate to very high. The residual risk can be determined after implementing controls to mitigate the risks.

| Threat Events                                                                                                          | Controls                                                                                                                   | Inherent Risk | Residual Risk |
|------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|---------------|---------------|
| Manipulation of MRI machine operational settings                                                                       | Implement Firewalls & Intrusion Prevention Systems (CIS Safeguard 13.10)                                                   | Very High     | Moderate      |
| DDOS attack on Cloud-based Electronic Health Record Management Software system                                         | Implement network traffic throttling (CIS control 13 - Safeguard 13.4: Perform Traffic Filtering Between Network Segments) | Moderate      | Low           |
| Malware attack to access Electronic Protected Health Information database                                              | Perform periodic software updates and vulnerability scanning (CIS Safeguard 7.4)                                           | Very High     | Moderate      |
| Employee modify or misuse critical health record data, or external contractors and third-party vendors steal this data | Implement role-based access control (CIS control 6 - Safeguard 6.8: Define and Maintain Role-Based Access Control)         | High          | Moderate      |

## Works Cited

Alder, Steve. *Serious Security Risks Found in Healthcare Laptops*, The HIPAA Journal, 14 Mar. 2019, [www.hipaajournal.com/serious-security-risks-found-in-healthcare-laptops/](http://www.hipaajournal.com/serious-security-risks-found-in-healthcare-laptops/). Accessed 8 Oct. 2025

BC Civil Liberties Association. *"Risks of Electronic Health Records."* *BC Civil Liberties Association*, n.d, [bccla.org/privacy-handbook/main-menu/privacy8contents/privacy8-11.html](http://bccla.org/privacy-handbook/main-menu/privacy8contents/privacy8-11.html). Accessed 8 Oct. 2025.

Canspace, *Why Expired Domains Are a Security Threat to Your Business* , canspace, 10 Aug. 2023,  
[www.canspace.ca/blog/security/why-expired-domains-are-a-security-threat-to-your-business/](http://www.canspace.ca/blog/security/why-expired-domains-are-a-security-threat-to-your-business/).  
Accessed 8 Oct. 2025

Electronic Office Systems, *What Security Concerns Should Be Addressed When Using Ethernet Connectivity?*, 27 Nov. 2023,  
[www.electronicofficesystems.com/2023/11/27/what-security-concerns-should-be-addressed-when-using-ethernet-connectivity/](http://www.electronicofficesystems.com/2023/11/27/what-security-concerns-should-be-addressed-when-using-ethernet-connectivity/). Accessed 8 Oct. 2025

Granot, Lian. "Operating System Vulnerabilities: Understanding and Mitigating the Risk." *Sternum* , Sternum , 18 Oct. 2024,  
[sternumiot.com/iot-blog/operating-system-vulnerabilities-understanding-and-mitigating-the-risk/](http://sternumiot.com/iot-blog/operating-system-vulnerabilities-understanding-and-mitigating-the-risk/).  
Accessed 8 Oct. 2025

Intelligent CIO Europe. "The 5 Most Common Router Attacks on a Network ." *Intelligent CIO Europe*, n.d.  
[www.intelligentcio.com/eu/2017/10/16/the-5-most-common-router-attacks-on-a-network/](http://www.intelligentcio.com/eu/2017/10/16/the-5-most-common-router-attacks-on-a-network/).  
Accessed 8 Oct. 2025.

Jewhurst, Hilary. *10 Types of Vendor Risks to Monitor*, Venminder, 7 Nov. 2024,  
[www.venminder.com/blog/types-vendor-risks-monitor](http://www.venminder.com/blog/types-vendor-risks-monitor). Accessed 8 Oct. 2025

Microsoft Ignite, *Best Practices for Securing Active Directory*, Microsoft Ignite, 21 May 2025,  
[learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory](https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory). Accessed 9 Oct. 2025

Microsoft Threat Intelligence, "Cloud Storage Security: What's New in the Threat Matrix." *Microsoft Security*, 7 Sept. 2023,  
[www.microsoft.com/en-us/security/blog/2023/09/07/cloud-storage-security-whats-new-in-the-threat-matrix/](http://www.microsoft.com/en-us/security/blog/2023/09/07/cloud-storage-security-whats-new-in-the-threat-matrix/). Accessed 8 Oct. 2025

Miller, Jodi. *HIPAA Guidelines for Reception Areas: What You Must Know*, notifyMD®, 12 Aug. 2025, [notifymd.com/blog/hipaa-violations-at-reception/](http://notifymd.com/blog/hipaa-violations-at-reception/). Accessed 8 Oct. 2025

Novatech. "Hackers Targeting Printers More: The Growing Security Threat." *Novatech*, 12 Aug. 2024, [novatech.net/blog/hackers-targeting-printers-more-the-growing-security-threat](http://novatech.net/blog/hackers-targeting-printers-more-the-growing-security-threat). Accessed 8 Oct. 2025

Nguyen, Xuan V, et al. "Cybersecurity in Radiology: Cautionary Tales, Proactive Prevention, and What to Do When You Get Hacked - Sciencedirect." *ScienceDirect*, ScienceDirect, Mar & Apr 2025, [www.sciencedirect.com/science/article/pii/S0363018824001221](http://www.sciencedirect.com/science/article/pii/S0363018824001221). Accessed 7 Oct. 2025

Open MedScience. "Enhancing Cybersecurity in Medical Imaging: Essential for Patient Safety", *Open MedScience Imaging Health*, 2 Jan. 2024,

[openmedscience.com/enhancing-cybersecurity-in-medical-imaging-essential-for-patient-safety/?utm\\_source=chatgpt.com](https://openmedscience.com/enhancing-cybersecurity-in-medical-imaging-essential-for-patient-safety/?utm_source=chatgpt.com). Accessed 8 Oct. 2025

OWASP Top 10:2021, "A09:2021 – Security Logging and Monitoring Failures." *A09 Security Logging and Monitoring Failures*, n.d., [owasp.org/Top10/A09\\_2021-Security\\_Logging\\_and\\_Monitoring\\_Failures/](https://owasp.org/Top10/A09_2021-Security_Logging_and_Monitoring_Failures/). Accessed 8 Oct. 2025.

RadSource. "Key Factors of Cybersecurity in Your PACS System." *RadSource*, 19 Sept. 2024, [radsources.us/key-factors-of-cybersecurity-in-your-pacs-system/](https://radsources.us/key-factors-of-cybersecurity-in-your-pacs-system/). Accessed 8 Oct. 2025

Sandoval, Fabian. "Cybersecurity Essentials for Appointment Management Systems." *TIMIFY*, TIMIFY, 2 Apr. 2025, [www.timify.com/en/blog/cybersecurity-essentials-for-appointment-management-systems/](https://www.timify.com/en/blog/cybersecurity-essentials-for-appointment-management-systems/). Accessed 8 Oct. 2025

SOPHOS. *What Is a Local Area Network (Lan)?*, SOPHOS, n.d. [www.sophos.com/en-us/cybersecurity-explained/local-area-network-lan](https://www.sophos.com/en-us/cybersecurity-explained/local-area-network-lan). Accessed 8 Oct. 2025.

Tran, Bao. *IOT Security Threats: How Vulnerable Are Smart Devices?*, PatentPC, 16 Sept. 2025, [patentpc.com/blog/iot-security-threats-how-vulnerable-are-smart-devices](https://patentpc.com/blog/iot-security-threats-how-vulnerable-are-smart-devices). Accessed 8 Oct. 2025

Zmed. "Emerging Cybersecurity Threats for Medical Billing Providers ." *Zmed*, 14 July 2025, [www.zmedsolutions.net/emerging-cybersecurity-threats-for-medical-billing-providers/](https://www.zmedsolutions.net/emerging-cybersecurity-threats-for-medical-billing-providers/). Accessed 8 Oct. 2025